SIMATS ENGINEERING

Engineer to Excel

SIMATS

Saveetha Institute of Medical And Technical Sciences

(Declared as Deemed to be University under Section 3 of UGC Act 1956)

ITA1434 – ETHICAL HACKING

ASSIGNMENT 2 -CO2

Name: D K Sumalatha

Reg no: 192424023

Evaluation and Engineering of Footprinting, Reconnaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment

Q1 – Evaluate and Engineer a Footprinting Strategy (8 Marks)

1. Introduction

Footprinting is the process of collecting information about an organization before performing a penetration test. It helps security professionals understand the target's public information and identify possible security risks.

A good footprinting strategy uses multiple information sources such as WHOIS, DNS records, search engines, and archived web pages. Using multiple sources provides more complete information than depending on a single source.

2. Objectives

- To collect information using different footprinting techniques.
- To identify the target's domain information and DNS records.
- To classify techniques as passive or active.
- To compare predicted information with actual observations.
- To evaluate the reliability of collected information.
- To design a strategy suitable for large-scale reconnaissance.

3. Footprinting Strategy

The following techniques are used:

Technique	**Tool**	**Type**	**Purpose**
WHOIS lookup	whois	Passive	Collect domain registration details
DNS lookup	nslookup	Passive query	Identify DNS records
DNS analysis	dig	Passive query	Retrieve DNS information
Search engine	Google	Passive	Find publicly available information
Archived pages	Wayback Machine	Passive	View historical website information
Authorized DNS testing	dig	Active when directly probing target infrastructure	Verify permitted DNS configurations

4. Commands Used

WHOIS lookup

whois example.com

DNS lookup using nslookup

nslookup example.com

Retrieve DNS A record

dig example.com A

Retrieve MX record

dig example.com MX

Retrieve NS record

dig example.com NS

Search engine operators

site:example.com

site:example.com filetype:pdf

site:example.com intitle:report

These commands should be used only with authorized assessment targets. The examples use a placeholder domain.

5. Four Contrasting Test Targets

Target	Description	Predicted Information
Target A	Well-protected domain	Limited public information
Target B	Information-leaking domain	Public documents and subdomains
Target C	Misconfigured DNS domain	Incorrect or excessive DNS information
Target D	Minimal public footprint	Very limited information

6. Prediction Versus Observation

The following is an illustrative test result.

Target	Prediction	Sample Observation	Result
A	Limited information	Only basic DNS and registration information	Matched
B	More public information	Several public documents and subdomains	Matched
C	DNS configuration issues	Inconsistent DNS records	Matched
D	Very little information	Only basic domain information	Matched

7. Source Reliability Analysis

- WHOIS: Useful for registration details, but privacy protection can hide information.
- DNS: Provides domain configuration details, but cached records may be outdated.
- Google: Helps identify publicly indexed information, but results may be incomplete.
- Archived pages: Useful for historical information, but old content may no longer be valid.

Information from different sources should be compared before accepting it as correct.

8. Strategy for Fifty Subdomains

When the assessment scope increases from one domain to fifty subdomains, the original strategy must be improved.

The modified strategy includes:

1. Prepare an authorized list of all fifty subdomains.
2. Perform DNS checks systematically.
3. Collect WHOIS and publicly available information where applicable.
4. Store findings in a structured spreadsheet.
5. Remove duplicate information.
6. Verify outdated and conflicting records.
7. Reject out-of-scope domains.
8. Prepare a final reconnaissance report.

Conclusion:

A multi-source footprinting strategy provides better information about an organization's attack surface. Combining WHOIS, DNS, search engines, and archived pages improves coverage and reliability. For fifty subdomains, automated collection and validation are useful for reducing repeated work while maintaining scope compliance.

Q2 – Build a Reliable DNS Footprinting Workflow (7 Marks)

1. Introduction

DNS (Domain Name System) converts domain names into IP addresses and provides information about domain configuration. DNS footprinting is used to identify the records associated with an authorized domain.

A reliable DNS workflow collects A, MX, NS, and TXT records and checks whether the DNS server is correctly configured.

2. Objectives

- To retrieve different DNS records.
- To understand DNS configuration.
- To identify stale or incorrect records.
- To understand zone transfer.
- To evaluate DNS security risks.
- To recommend suitable countermeasures.

3. DNS Footprinting Workflow



4. Commands Used

A Record

dig example.com A

MX Record

dig example.com MX

NS Record

dig example.com NS

TXT Record

dig example.com TXT

Using nslookup

nslookup

set type=A

example.com

Other record types can be checked by replacing A with MX, NS, or TXT.

Zone transfer: Only against a lab-owned DNS server or a server for which explicit permission has been granted.

dig @<authorized-dns-server> <authorized-zone> AXFR

5. Six Contrasting DNS Test Cases

Case	DNS Configuration	Expected Result
1	Correctly secured DNS	Normal DNS records
2	Zone transfer enabled	Zone information may be exposed
3	Stale DNS records	Old IP address may appear
4	Split-horizon DNS	Different internal and external responses
5	Third-party DNS delegation	Records managed by another DNS provider
6	Missing DNS records	Some queries return no records

6. Prediction Versus Observation

Illustrative results:

Case	Prediction	Sample Observation
1	Correct records	Expected A, MX, NS and TXT records returned
2	Zone data exposed	Authorized lab transfer returned zone entries
3	Old records	Previous IP address returned
4	Different responses	Internal and external answers differed
5	Delegated records	Third-party nameservers identified
6	Missing records	No answer returned for the missing record

7. DNS Security Problems

Split-horizon DNS: Internal and external users receive different DNS responses. This can limit the information visible to an external tester.

DNS Delegation: A domain's DNS management is assigned to another DNS server or provider.

DNS Caching: DNS resolvers temporarily store records. Old cached information may be returned until its TTL expires.

Zone Transfer: A zone transfer copies DNS zone information between DNS servers. If unrestricted, it may expose internal hostnames and network structure.

8. Countermeasures

- Restrict zone transfers to authorized secondary DNS servers.
- Use TSIG authentication for zone transfers.
- Remove outdated DNS records.
- Review DNS delegation regularly.
- Use appropriate TTL values.
- Monitor DNS server activity.

9. Redesign After Countermeasures

After restricting zone transfers and introducing TSIG, unauthorized zone transfer requests should fail, while authorized secondary servers can continue receiving updates.

Conclusion:

DNS footprinting helps identify domain configuration and possible security weaknesses. Proper analysis of DNS records, caching, delegation, and zone transfers improves reconnaissance accuracy. Restricting zone transfers and using TSIG reduces unnecessary information exposure.

Q3 – Create a Competitive-Intelligence Awareness Utility (7 Marks)

1. Introduction

Competitive intelligence is the process of collecting publicly available information about an organization. Information from job advertisements, annual reports, press releases, and public profiles can reveal details about an organization's activities and technologies.

This information may also create human security risks if attackers misuse it for phishing, vishing, pretexting, or tailgating. Therefore, competitive intelligence should be used to improve security awareness.

2. Objectives

- To collect publicly available organizational information.
- To identify possible social-engineering risks.
- To classify information based on attack techniques.
- To develop security awareness recommendations.
- To evaluate the risk of different public sources.

3. Workflow Architecture



4. Public Information Sources and Search Operators

Source	Search Operator	Information Collected
Job advertisements	site:example.com/jobs	Job roles and required technologies
Annual reports	site:example.com filetype:pdf	Organizational activities
Press releases	site:example.com intitle:press	Company announcements
Public profiles	site:linkedin.com/company	Public company information

These searches should be limited to publicly available information and the authorized organization.

5. Mapping Information to Social-Engineering Techniques

Collected Information	Possible Technique	Risk Indicator
Employee job roles	Phishing	Email pretending to be from a department
Public phone numbers	Vishing	Unexpected calls requesting confidential information
Company projects	Pretexting	False claims about project-related work
Office location	Tailgating	Unknown visitors attempting to enter restricted areas

6. Three Test Organizations

Organization	Public Information	Expected Risk
Organization A	Rich information	High
Organization B	Limited information	Low
Organization C	Misleading information	Medium

7. Prediction Versus Observation

Illustrative test results:

Organization	Prediction	Sample Observation
A	More employee and project information	Multiple public records identified
B	Limited information	Only basic company details found
C	Conflicting information	Some outdated information identified

8. Risk Evaluation

- Job advertisements may reveal technology and department details.
- Annual reports may reveal business operations and major projects.
- Press releases may expose project timelines and organizational changes.
- Public profiles may reveal employee roles and professional relationships.

Public employee information combined with organizational details can increase the risk of targeted phishing and pretexting. The most dangerous source depends on the information disclosed and its reliability.

9. Additional Sources and Countermeasures

Two additional sources:

1. Public conference presentations.
2. Public vendor and partnership announcements.

Two awareness countermeasures:

1. Conduct regular phishing-awareness training.
2. Verify unexpected phone calls and visitor identities before sharing information or granting access.

Conclusion:

Competitive intelligence helps organizations understand how publicly available information can create human security risks. By mapping information to social-engineering techniques, organizations can improve employee awareness and develop suitable security countermeasures.

Q4 – Design a Reconnaissance Data-Validation Mechanism (6 Marks)

1. Introduction

Reconnaissance data may contain incomplete, outdated, duplicated, or unauthorized information. Using incorrect information can lead to wrong security decisions.

A data-validation mechanism checks each collected item before including it in the final reconnaissance report.

2. Objectives

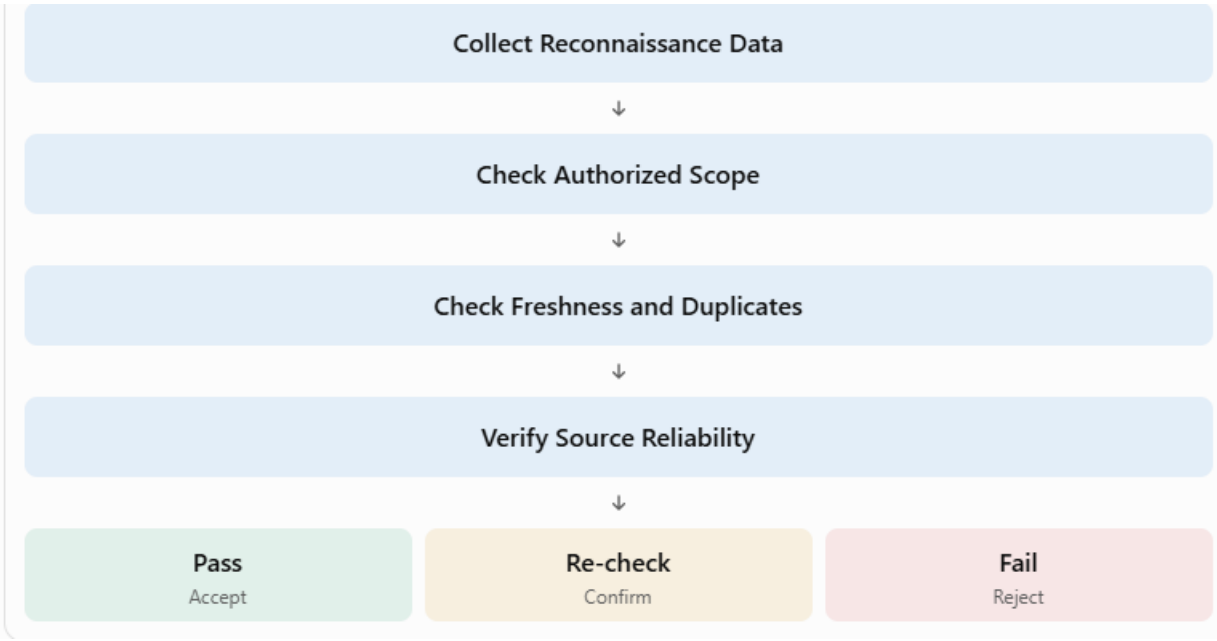
- To validate collected reconnaissance information.
- To identify out-of-scope information.
- To detect outdated records.
- To remove duplicate information.
- To evaluate source reliability.
- To reduce unnecessary validation effort.

3. Validation Mechanism

The validation process uses four important checks:

1. Scope Check: Confirms whether the information belongs to the authorized target.
2. Freshness Check: Checks whether the information is current.
3. Duplicate Check: Identifies repeated information.
4. Source Reliability Check: Verifies whether the source is trustworthy.

4. Validation Workflow



5. Validation Rules

Condition	Action
Authorized and verified information	Pass
Out-of-scope information	Reject
Outdated information	Re-check
Duplicate information	Remove duplicate
Unreliable source	Re-check or reject
Unverifiable information	Reject

6. Five Test Sequences

The following are illustrative test cases.

Test Case	Input Condition	Expected Result
1	All valid information	Pass
2	Out-of-scope domain	Fail
3	Old DNS record	Re-check
4	Duplicate IP address	Remove duplicate
5	Unverified public information	Re-check or reject

7. Prediction Versus Observation

Assume five items are submitted for validation.

Item	Prediction	Sample Result
Item 1	Pass	Pass
Item 2	Reject	Fail

Item 3	Re-check	Re-check
Item 4	Remove duplicate	Duplicate removed
Item 5	Re-check	Re-check

Sample validation summary

1

Passed

1

Failed

2

Re-check

One additional duplicate item was removed.

8. Validation Order Evaluation

The original approach may check source reliability before checking whether the information is within scope. This wastes time on unauthorized information.

The improved validation order is:

1. Scope validation.
2. Duplicate detection.
3. Freshness validation.
4. Source reliability verification.

This approach rejects out-of-scope information early and avoids unnecessary checks.

9. Scalability from One to Fifty Targets

For fifty targets, manual validation becomes time-consuming. A structured database or spreadsheet can store domain names, collection dates, sources, duplicate status, and validation results.

Conclusion:

A reconnaissance data-validation mechanism improves the accuracy and reliability of collected information. Checking scope first, followed by duplicate, freshness, and source reliability checks, reduces unnecessary effort and prevents unauthorized information from entering the final report.

Q5 – Evaluate Footprinting of a Hierarchical Organization (7 Marks)

1. Introduction

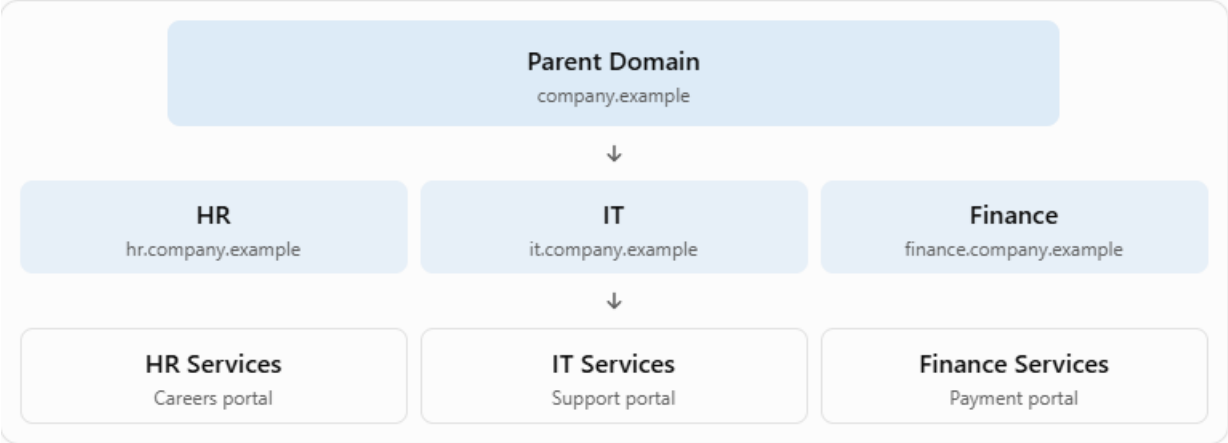
A hierarchical organization contains different levels of domains, subdomains, departments, and third-party services. Footprinting such an organization requires systematic collection of information from each level.

A hierarchical traversal method helps identify all authorized nodes without moving outside the defined scope.

2. Objectives

- To represent an organization's footprint in hierarchical form.
- To identify parent domains, subdomains, and services.
- To design a systematic traversal method.
- To identify empty branches and terminal nodes.
- To compare predicted and actual node coverage.
- To maintain authorized scope during reconnaissance.

3. Hierarchical Footprint Representation



4. Systematic Traversal Method

Breadth-First Search (BFS) can be used to visit the hierarchy level by level.

Steps:

1. Start with the authorized parent domain.
2. Add the parent domain to a queue.
3. Visit the first node in the queue.
4. Identify its authorized child nodes.
5. Add unvisited child nodes to the queue.
6. Stop at terminal nodes or when a node is outside the authorized scope.
7. Continue until the queue becomes empty.
8. Record all visited nodes.

5. Pseudocode

START

Create an empty queue

Create an empty visited list

Add parent domain to queue

WHILE queue is not empty:

    Remove first node from queue

    IF node is outside authorized scope:
        Skip node
        Continue

    IF node is already visited:
        Continue

    Add node to visited list

    Collect available public information

    IF node has child nodes:
        Add authorized children to queue

    ELSE:
        Mark node as terminal

END WHILE

Display visited nodes
Generate final footprint report

STOP

6. Three Test Structures

Test Case 1 – Shallow Footprint

Organization
├── HR
├── IT
└── Finance

Expected nodes: 4 (one parent and three children).

Test Case 2 – Deeply Nested Footprint

Organization

└── IT

    └── Security

        └── Network

            └── Monitoring

Expected nodes: 5.

Test Case 3 – Irregular Footprint

Organization

├── HR

│   ├── Recruitment

│   └── Payroll

├── IT

│   └── Support

└── Finance

    ├── Accounts

    └── Empty Branch

Expected nodes: 9 (one parent and eight child nodes).

7. Prediction Versus Observation

Illustrative test results:

Test Structure	Expected Nodes	Sample Visited Nodes	Coverage
Shallow	4	4	100%
Deep	5	5	100%
Irregular	9	9	100%

Coverage is calculated as:

$$Coverage = \frac{Visited\ Nodes}{Expected\ Nodes} \times 100$$

For the irregular structure:

$$Coverage = \frac{9}{9} \times 100 = 100\%$$

8. Boundary Condition

A boundary condition is used to prevent traversal outside the authorized scope.

The traversal should stop or skip a node when:

- The node is outside the authorized domain.
- The node is already visited.
- The node has no child nodes.
- The node contains no publicly available information.

An empty branch should be recorded as having no public data. It should not cause the traversal to fail.

9. BFS Versus Ad-hoc Footprinting

BFS Systematic Approach	**Ad-hoc Approach**
Visits nodes level by level	Visits nodes randomly
Maintains a visited list	May repeat nodes
Supports scope checking	Scope control may be inconsistent
Provides better coverage tracking	May miss branches
Easier to document	Difficult to organize

10. Evaluation

The depth of the hierarchy increases the number of traversal levels. Branching increases the number of nodes that must be visited.

BFS provides systematic coverage, while the boundary condition prevents unauthorized traversal. The visited list also prevents repeated collection.

Conclusion:

Hierarchical footprinting helps understand the structure of an organization. BFS provides a systematic method for identifying authorized domains, subdomains, and services. Proper boundary conditions ensure that the traversal stops at terminal or out-of-scope nodes without missing authorized branches.

Q6 – Evaluate Footprinting Approaches Under Constraints (7 Marks)

1. Introduction

Footprinting can be performed using different information-gathering approaches. The two important approaches are passive open-source collection and active DNS footprinting.

Both methods provide useful information, but they differ in speed, coverage, resource requirements, and detection risk.

2. Objectives

- To compare passive and active footprinting.
- To apply both approaches to the same authorized target.
- To measure queries and collection effort.

- To identify repeated and unnecessary queries.
- To evaluate the relationship between speed and completeness.
- To recommend suitable approaches for small and large engagements.

3. Two Information-Gathering Approaches

Approach 1 – Passive Open-Source Collection

Passive footprinting collects information from publicly available sources without directly probing the target's infrastructure.

Examples:

- WHOIS information.
- Search engine results.
- Public documents.
- Archived web pages.
- Public company information.

Approach 2 – Active DNS Footprinting

Active DNS footprinting directly sends permitted queries to DNS infrastructure to collect domain information.

Examples:

- DNS A record queries.
- MX record queries.
- NS record queries.
- TXT record queries.
- Authorized DNS configuration checks.

4. Workflow Comparison

Passive Approach	**Active DNS Approach**
Identify authorized domain	Identify authorized domain
Search public information	Query DNS records
Collect public documents	Collect A, MX, NS and TXT records
Review archived pages	Verify DNS responses
Validate information	Identify configuration issues
Prepare report	Prepare report

5. Four Increasing Scope Sizes

The following are illustrative test conditions using the same authorized test organization.

Test	**Scope Size**	**Passive Approach**	**Active DNS Approach**
1	1 domain	Easy	Easy

2	5 subdomains	Easy	Easy
3	20 subdomains	Moderate	Moderate
4	50 subdomains	More manual effort	Requires systematic query management

6. Quantitative Measurement

Sample experimental measurements:

Scope	Passive Queries	Active DNS Queries
1 domain	4	4
5 subdomains	20	20
20 subdomains	80	80
50 subdomains	200	200

Assumption: Four collection operations are performed for each target in each approach. These are planned operation counts, not actual measured network requests.

7. Coverage Comparison

Factor	Passive Footprinting	Active DNS Footprinting
Public information	High potential	Limited
DNS information	Depends on public sources	Directly retrieved
Detection risk	Generally lower	Can be higher
Speed	Depends on source	Can be automated
Completeness	May miss unindexed data	Limited to queried DNS data
Repeated collection	Possible	Possible

8. Redundancy Analysis

Redundancy means collecting the same information more than once.

Examples:

- Searching for the same PDF through multiple search operators.
- Querying the same DNS record repeatedly.
- Collecting the same subdomain from different sources.
- Recording the same IP address multiple times.

Solutions:

1. Maintain a centralized data collection sheet.
2. Use unique identifiers for each domain.
3. Store query history.
4. Remove duplicate results.
5. Verify information before adding it to the final report.

9. Is the Faster Approach Always Better?

No. The faster approach is not always the best engineering choice.

Passive collection is suitable when low detection risk is important. Active DNS footprinting is useful when direct DNS information is required.

A faster approach may produce incomplete information. A quieter approach may also miss important DNS configuration details.

Therefore, the approach should be selected based on the engagement's objectives and limitations.

10. Final Recommendations

Engagement	**Recommended Approach**	**Reason**
Small-scope assessment	Combination of passive and active	Provides balanced information
Large-scope assessment	Automated, controlled combination	Reduces repeated work
Low-detection requirement	Passive collection first	Minimizes direct interaction
DNS configuration analysis	Authorized active DNS queries	Provides direct DNS responses

11. Evaluation

For small engagements, manual passive collection combined with a few authorized DNS queries is sufficient.

For large engagements involving fifty subdomains, systematic collection, automation, centralized storage, and duplicate removal are necessary.

Conclusion:

Passive and active footprinting approaches have different advantages. Passive footprinting reduces direct interaction, while active DNS footprinting provides more direct DNS information.

Combining both approaches produces better results when speed, completeness, and scope compliance are considered together.

Q7 – Integrated Review: Diagnose, Redesign and Defend (8 Marks)

Selected Workflow: Q4 – Reconnaissance Data-Validation Mechanism

1. Introduction

Reconnaissance data validation is an important process in ethical hacking. Collected information may contain duplicate, outdated, unreliable, or out-of-scope data.

The original validation workflow may waste time by checking source reliability before verifying whether the information belongs to the authorized target.

This question improves the original workflow by changing the validation order and comparing its performance with the redesigned workflow.

A. Diagnose the Limitation (2 Marks)

1. Identified Limitation

The original validation workflow performs source reliability checks before scope validation. This creates unnecessary work because information from unauthorized domains may undergo additional checks even though it should be rejected.

2. Causes of the Limitation

- Poor validation order.
- Repeated checking of duplicate information.
- Unnecessary processing of out-of-scope data.
- Time wasted on unreliable information.
- Difficulty handling large amounts of reconnaissance data.

3. Example

Suppose five reconnaissance items are collected:

Item	Description	Problem
1	Authorized domain	Valid
2	Unauthorized domain	Out of scope
3	Old DNS record	Outdated
4	Repeated IP address	Duplicate
5	Unverified document	Unreliable

The original workflow may spend time checking all five items before rejecting unauthorized information.

Diagnosis: The main limitation is poor ordering of validation checks, which increases unnecessary processing.

B. Establish Evaluation Criteria (1 Mark)

The original and redesigned workflows are evaluated using the following criteria.

Evaluation Criteria	Description
Coverage	Number of valid items identified
Query Count	Number of validation operations
Source Reliability	Trustworthiness of collected information
Scope Compliance	Ability to reject unauthorized information
Processing Effort	Number of unnecessary checks

These criteria help determine whether the redesigned workflow provides better results.

C. Propose and Implement a Redesign (2 Marks)

1. Original Workflow

1. Collect reconnaissance information.

2. Check source reliability.
3. Check freshness.
4. Check duplicates.
5. Check authorized scope.
6. Generate the report.

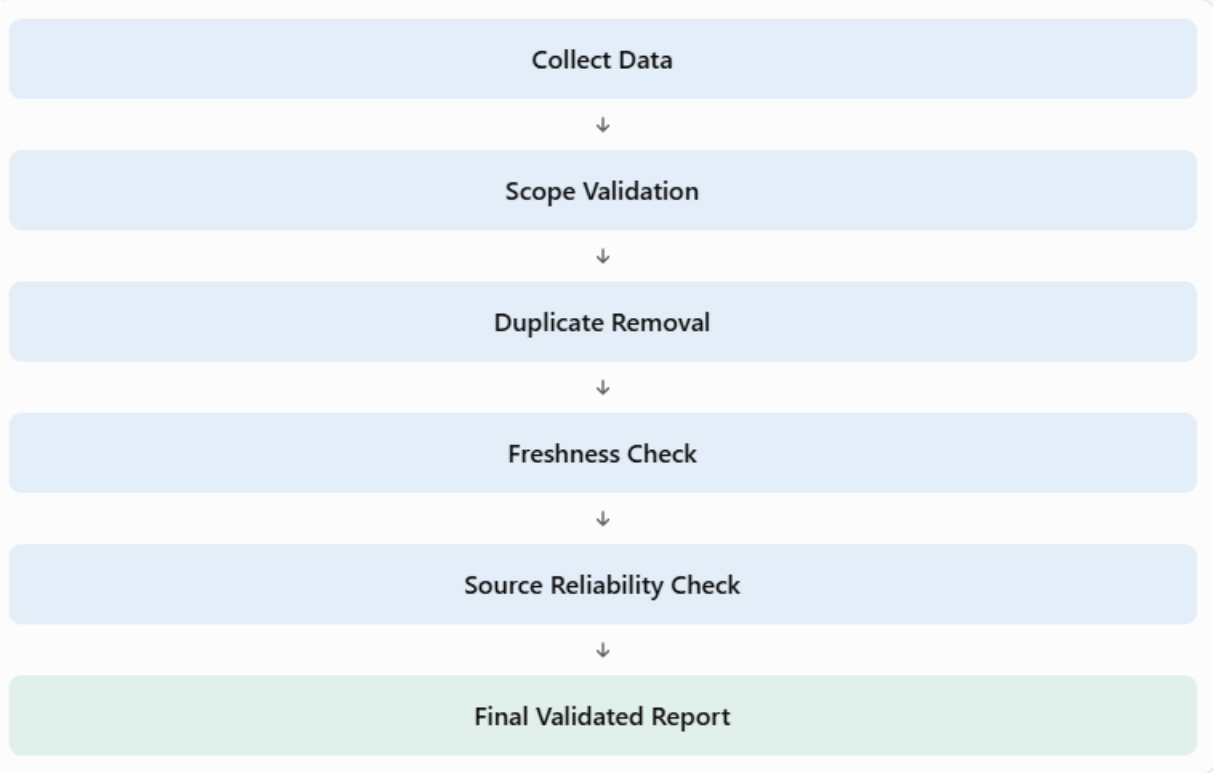
2. Redesigned Workflow

The redesigned workflow checks authorized scope first and removes duplicate information before performing other checks.

New validation order:

1. Collect reconnaissance information.
2. Check authorized scope.
3. Remove duplicate information.
4. Check freshness.
5. Verify source reliability.
6. Accept, re-check, or reject the information.
7. Generate the final report.

3. Redesigned Workflow Diagram



4. Trade-Offs

Advantages:

- Reduces unnecessary validation work.

- Rejects unauthorized information early.
- Prevents repeated data processing.
- Improves validation efficiency.

Limitations:

- Requires a properly maintained authorized-scope list.
- Incorrect scope configuration may reject valid information.
- Freshness and reliability checks are still necessary.

D. Validate and Compare (2 Marks)

1. Test Conditions

Both workflows are tested using the same five reconnaissance items.

Item	Test Condition	Expected Result
1	Authorized and current information	Pass
2	Unauthorized domain	Reject
3	Outdated DNS record	Re-check
4	Duplicate IP address	Remove duplicate
5	Unverified document	Re-check

2. Original Workflow Results

Illustrative operation counts:

Item	Validation Operations	Result
1	4	Pass
2	4	Reject
3	4	Re-check
4	4	Duplicate removed
5	4	Re-check
Total	20	

3. Redesigned Workflow Results

Illustrative operation counts:

Item	Validation Operations	Result
1	4	Pass
2	1	Reject
3	4	Re-check
4	2	Duplicate removed
5	4	Re-check

Total	15	

4. Comparison of Both Workflows

Criteria	Original	Redesigned
Total items	5	5
Passed	1	1
Rejected	1	1
Re-check required	2	2
Duplicate removed	1	1
Validation operations	20	15

5. Improvement Calculation

$$Improvement = \frac{20 - 15}{20} \times 100$$

$$= \frac{5}{20} \times 100$$

$$= \boxed{25\%}$$

25% fewer validation operations

The redesigned workflow reduces the illustrative validation operations from 20 to 15 while maintaining the same classification results.

E. Defend the Final Engineering Judgment (1 Mark)

The redesigned workflow is better for large-scale reconnaissance because it performs scope validation first and removes duplicate information early.

It reduces unnecessary validation operations and ensures that unauthorized information is rejected before additional processing.

However, the original workflow may still be suitable for very small datasets where processing effort is not a major concern.

Final Engineering Decision:

The redesigned workflow is recommended because it improves processing efficiency, maintains scope compliance, and provides the same validation results under equivalent test conditions.

Conclusion:

The integrated review demonstrates that improving the order of validation checks can reduce unnecessary processing. The redesigned workflow provides a more efficient and reliable method for handling reconnaissance information.